NURTUREPATH AI / SAFEHER

Codex Production & Hosting Prompt

Deployment architecture, operational readiness, security, safeguarding and controlled real-world rollout.

Version 1.0 | 12 October 2026 | Ghana-first | UNFPA SafeTech Africa HackLab 2026

Codex mandate and prerequisites

Act as production architect, security engineer, DevOps lead and safeguarding implementation lead. Inspect the working SafeHer MVP before changing anything. Create a release branch and a gap analysis. Do not connect real users or process sensitive disclosures until governance gates are passed. Preserve original project history and provide rollback plans.

Production readiness gates

Gate 1: verified legal operator and privacy owner; Gate 2: documented child safeguarding policy, qualified clinical/SRHR content reviewer, local legal review, risk assessment and verified service partners; Gate 3: threat model and security review; Gate 4: accessibility and usability testing with consenting adults; Gate 5: incident response and data subject rights workflows. No production sensitive referral processing before all gates pass.

Clarify data-controller/processor roles and lawful basis, age-sensitive consent and mandatory reporting obligations with qualified Ghana counsel. Avoid claiming full compliance based only on code.

Reference hosting architecture

Use Next.js frontend on Vercel or equivalent managed hosting, API in protected server runtime, PostgreSQL on a managed provider with point-in-time recovery, object storage only for approved public assets, DNS with TLS and managed secrets. Choose provider region and contracts based on data residency/legal review. Keep dev, staging and production environments separate.

Implement infrastructure-as-code or documented reproducible configuration. Enforce production HTTPS, secure headers, WAF/rate limits, minimal outbound AI data, service-to-service auth and no public database exposure. Provide estimated costs by environment as assumptions, not fabricated quotes.

Environment, domains and CI/CD

Create .env.example and secrets inventory; never commit keys. Configure production domain, SPF/DKIM/DMARC if transactional email is used, TLS renewal, health checks, automated migrations with approval, GitHub Actions for lint/typecheck/tests/build/dependency scans and protected production deploy.

Staging uses synthetic data only. Require approval for production database schema changes. Document rollback for frontend, API and migrations, with explicit restore drills.

Production AI governance

Build a curated, source-linked, human-approved knowledge base with review expiry, retrieval citations, confidence/uncertainty rules and content rollback. Prevent prompt injection from retrieved pages, redact logs, limit input size, rate-limit use, monitor safety failures and run structured evaluation before every AI change.

Do not transmit names, disclosures or other sensitive information to an AI vendor without an approved data-processing agreement and clear user notice. Provide an AI-off fallback showing vetted static information.

Directory verification and safeguarding

Use documented partner verification, date of last verification, review schedule, escalation contacts and delisting process. Do not launch an automated referral integration without a signed agreement, partner training, explicit consent and safety assessment.

Prepare high-risk response scripts reviewed by safeguarding specialists; never claim real-time monitoring or emergency dispatch. Quick Exit limitations must remain visible.

Security controls

Enforce least-privilege RBAC and server authorization, admin MFA, secure sessions, rate limiting, audit events without sensitive payloads, vulnerability scans, dependency pinning, secret rotation, backup encryption and deletion requests. Run OWASP ASVS-inspired review, penetration test and third-party service risk assessment.

Configure alerting for authentication anomalies, elevated errors and data export events. Document incident severity levels, response contacts, breach notification decision process and rehearsals.

Monitoring, backups and resilience

Monitor uptime, latency, error rates, queue delays, broken content references, partner verification expiry and AI safety failure categories using aggregate metrics. Do not collect raw chat content in telemetry. Backups encrypted with retention and restore drills; set RPO/RTO targets only after operator approval.

Provide degraded-mode behavior when AI, SMS, database or connectivity is unavailable. Make informational content usable where possible without requiring identity.

Accessibility, localization and content operations

Test on low-end Android, iOS, tablets and desktop; 320px width minimum. Run keyboard, screen-reader and WCAG 2.2 AA checks. Keep all critical translations human-reviewed and traceable. Establish content review cadence and user feedback triage.

Use progressive enhancement, public-article offline caching and low-data assets; never offline-cache personal chat or referral payloads by default.

Rollout plan

Phase A: internal staging and synthetic demos. Phase B: limited adult usability tests without sensitive disclosures. Phase C: partner-verified public information pilot after governance approval. Phase D: optional consent-based referrals after legal, security and safeguarding approvals. Phase E: multi-region scale only with verified directory coverage.

Define go/no-go checklist for each phase, owners, evidence and exit criteria. Do not mark a phase complete without recorded evidence.

Final production deliverables

Provide architecture diagram, deployment playbook, environment matrix, threat model, data flow map, data inventory, privacy and safeguarding review checklist, runbooks, backup/restore instructions, monitoring dashboards, cost assumptions, service verification SOP, incident plan, accessibility report and tested release notes.

Finish with exact deployment commands, verified test results, remaining blockers and a list of features intentionally disabled pending governance approvals.